

1. Explain Ransomware

Ransomware is a type of malicious software (malware) that blocks access to a computer or encrypts important files, making them unusable. The attacker then demands a ransom payment, usually in cryptocurrency, in exchange for a decryption key to restore the files.

Ransomware attacks often begin through phishing emails, malicious downloads, weak passwords, or unpatched software vulnerabilities. Once inside a system, the malware spreads across the network, encrypts files, and may also steal sensitive data before displaying a ransom note.

Ransomware has become one of the most common cyber threats because it can cause financial loss, business disruption, and damage to an organization's reputation.

Common ways ransomware spreads

- Phishing emails with malicious attachments or links.
- Remote Desktop Protocol (RDP) attacks using weak passwords.
- Exploiting unpatched software vulnerabilities.
- Malicious websites and software downloads.
- Infected USB devices.

2. List Indicators of a Ransomware Attack

Before and during a ransomware attack, several warning signs may appear. Some common indicators include:

- Files suddenly become inaccessible or encrypted.
- File extensions change (for example, **.locked**, **.encrypted**, or other unusual extensions).
- A ransom note appears demanding payment.
- Unusual spikes in CPU, memory, or disk usage.
- Security software is disabled without authorization.
- Multiple failed login attempts or suspicious user activity.
- Unknown processes running on computers.
- Large numbers of files being modified or renamed in a short period.
- Unusual network traffic or communication with unknown external servers.
- Users report that shared folders or network drives cannot be accessed.

SOC analysts often monitor these indicators through SIEM tools, endpoint detection systems, and log analysis to identify ransomware activity as early as possible.

3. Describe Response Steps

If a ransomware attack is detected, it is important to respond quickly to reduce its impact. A typical incident response includes the following steps:

Step 1: Identify the Attack

Confirm that ransomware is responsible for the unusual activity by checking alerts, logs, affected files, and ransom notes.

Step 2: Isolate Infected Systems

Disconnect affected computers from the network to prevent the ransomware from spreading to other devices or shared folders.

Step 3: Notify the Incident Response Team

Report the incident to the organization's Security Operations Center (SOC), IT team, and management so that the response process can begin immediately.

Step 4: Investigate the Incident

Determine how the ransomware entered the system, identify affected devices, and assess the extent of the damage.

Step 5: Remove the Malware

Use trusted antivirus or endpoint detection tools to remove the ransomware and ensure the infected systems are clean before restoring operations.

Step 6: Recover Data

Restore files from clean backups after verifying that the malware has been completely removed. Avoid restoring from backups that may also be infected.

Step 7: Strengthen Security

After recovery, update systems, apply security patches, reset compromised passwords, enable Multi-Factor Authentication (MFA), and educate employees on phishing awareness to reduce the risk of future attacks.